

RAPPORT DE SECURITE

DevSecOps Zero Trust Pipeline

Build #46 — 24 May 2026 a 18:04

Etape	Outil	Resultat	Statut
SAST	Semgrep	1 finding(s)	■
SCA	Trivy	0 CVE (0 CRITICAL / 0 HIGH)	■
BUILD	Docker	zerotrust-app:46	■
SCAN	Trivy image	Image scannee — exit-code 0	■
DAST	OWASP ZAP	1 alerte(s)	■
IA	AI Security Guard	3 agents : Anti-Tamper / Remediation / Explicatif	■
GATE	Security Gate	Score : 95/100 — PASS	■
SIGN	Cosign	Signature keyless appliquee	■

1 — Analyse Statique (SAST — Semgrep)

Fichier	Regle / Check ID	Severite	Ligne
test-app/app.py	.audit.app-run-param-config.avoid_app_run_with_bad_host	WARNING	117

2 — Analyse des Dependances (SCA — Trivy)

Aucune CVE detectee.

3 — Analyse Dynamique (DAST — OWASP ZAP)

Niveau de risque	Nombre d'alertes
Low	1

Alerte	Risque	Confiance	Instances
Server Leaks Version Information via "Server" HTTP Response Heade	Low	3	1

4 — AI Security Guard

4.1 — Anti-Tampering

Pipeline verifie — aucune modification non autorisee detectee.

4.2 — Remediation CVE (IA)

CVE	Package	Priorite	Correction requirements.txt
CVE-2023-50447	Pillow	CRITICAL	Pillow>="10.2.0"
CVE-2023-44271	Pillow	HIGH	Pillow<="10.0.0"
CVE-2023-4863	Pillow	HIGH	Pillow>="10.0.1"
CVE-2024-28219	Pillow	HAUTE	Pillow>=10.3.0

4.3 — Rapport Explicatif (IA)

Rapport d'Analyse de Sécurité

Executive Summary

Ce rapport présente les résultats des scans de sécurité effectués sur notre application Python. Aucune CVE n'a été détec

Findings Critiques

Semgrep - [WARNING] avoid_app_run_with_bad_host

- **Identifiant** : CWE-522 (Running application with an insecure host)

- **Vecteur d'attaque** : Exposition du serveur à l'intérieur de la zone réseau local

- **Composant/Endpoint affecté** : test-app/app.py

- **Impact opérationnel** : L'exposition du serveur pourrait permettre à un attaquant de prendre le contrôle de l'applic

- **Exploitabilité** : Faible, car il s'agit d'une configuration non sécurisée.

Rapport complet disponible : rapport-explicatif.md

5 — Security Gate

Score de securite	Grade	Seuil requis	Decision
95/100	A	90/100	DEPLOIEMENT AUTORISE

Categorie	Nombre	Poids unitaire	Impact total
SAST HIGH	1	-5 pts chacun	-5 pts

6 — Build Docker & Signature Cosign

Propriete	Valeur
Image Docker	zerotrust-app:46
Build number	46
Date	24/05/2026 a 18:04:44
Base image	python:3.11-slim (Debian 13)
Utilisateur runtime	appuser (non-root — Zero Trust)
Signature	Cosign v3 — keyless OIDC (fallback local)
Scan image	Trivy — exit-code 0 (resultats archives)